

Федеральное государственное бюджетное образовательное учреждение
высшего образования

«Казанский национальный исследовательский технический университет
им. А.Н. ТУПОЛЕВА-КАИ»

(КНИТУ-КАИ)

Кафедра систем информационной безопасности
Отделение СПО ИКТЗИ

МЕТОДИЧЕСКИЕ УКАЗАНИЯ

к выполнению практической работы № 1
по дисциплине

«Основы информационной безопасности»

на тему

**«Подсистемы парольной аутентификации пользователей.
Генераторы паролей. Оценка стойкости парольной защиты»**

Практическая работа № 1

по дисциплине

«Информационная безопасность»

Подсистемы парольной аутентификации пользователей.

Генераторы паролей. Оценка стойкости парольной защиты

Цель работы – исследование парольных подсистем аутентификации пользователей.

ТЕОРЕТИЧЕСКИЙ МАТЕРИАЛ

Под идентификацией пользователя понимают присвоение ему некоторого несекретного идентификатора, который он должен предъявить системе защиты информации (СЗИ) при осуществлении доступа к объекту. В качестве идентификатора используется, например, логин, физическое устройство и др.

Под аутентификацией понимают подтверждение пользователем своего идентификатора, проверка его подлинности. Данный этап необходим для устранения фальсификации идентификатора, предотвращения несанкционированного доступа в случае утери пользователем идентификатора.

Подсистемы идентификации и аутентификации пользователя играют важную роль для систем защиты информации.

Стойкость подсистемы идентификации и аутентификации пользователя в СЗИ во многом определяет устойчивость к взлому самой СЗИ. Данная стойкость определяется гарантией того, что злоумышленник не сможет пройти аутентификацию, присвоив чужой идентификатор или украв его.

Парольные системы идентификации/аутентификации являются одними из основных и наиболее распространенных в СЗИ методами пользовательской аутентификации в силу их простоты и прозрачности. В данном случае, информацией, аутентифицирующей пользователя, является некоторый секретный пароль, известный только легальному пользователю.

Парольная аутентификация пользователей является, как правило, передним краем обороны системы защиты информации. В связи с этим, модуль аутентификации по паролю наиболее часто подвергается атакам со стороны злоумышленника. Цель злоумышленника в данном случае – подобрать аутентифицирующую информацию (пароль) легального пользователя.

Методы парольной аутентификации пользователя являются наиболее простыми методами аутентификации и при несоблюдении определенных требований к выбору пароля являются достаточно уязвимыми.

Основными минимальными требованиями к выбору пароля и к подсистеме парольной аутентификации пользователя являются следующие.

К паролю:

1. Минимальная длина пароля должна быть не менее 6 символов.
2. Пароль должен состоять из различных групп символов (малые и большие латинские буквы, цифры, специальные символы ‘(’, ‘)’, ‘#’ и т.д.).
3. В качестве пароля не должны использоваться реальные слова, имена, фамилии и т.д.

К подсистеме парольной аутентификации:

1. Администратор СЗИ должен устанавливать максимальный срок действия пароля, после чего пароль должен быть сменен.
2. Должно быть установлено ограничение числа попыток неправильного ввода пароля (как правило, не более 3).
3. В подсистеме парольной аутентификации должна быть установлена временная задержка при вводе неправильного пароля.

Как правило, для помощи администратору безопасности при формировании паролей подчиненных ему пользователей, удовлетворяющих перечисленным требованиям, используются особые программы – автоматические генераторы паролей пользователей.

При выполнении перечисленных требований к паролям и к подсистеме парольной аутентификации единственно возможным способом для взлома данной подсистемы является прямой перебор паролей (brute forcing).

Количественная оценка стойкости парольной защиты

Пусть A – мощность алфавита паролей (количество символов, которые могут быть использованы при составлении пароля). Например, если пароль состоит только из малых английских букв, то $A=26$.

L – длина пароля.

$S = A^L$ – число всевозможных паролей длины L , которые можно составить из символов алфавита A .

V – скорость перебора паролей злоумышленником.

T – максимальный срок действия пароля.

Тогда, вероятность P подбора пароля злоумышленником в течение срока его действия T определяется по следующей формуле:

$$P = \frac{V * T}{S} = \frac{V * T}{A^L}.$$

Эту формулу можно использовать для решения обратной задачи.

ЗАДАЧА. Определить минимальные мощность алфавита паролей A и длину паролей L , обеспечивающих вероятность подбора пароля злоумышленником не более заданной P , при скорости подбора паролей V , максимальном сроке действия пароля T .

Следует заметить, что данная задача имеет неоднозначное решение. При исходных данных V, T, P однозначно можно определить лишь нижнюю границу S^* числа всевозможных паролей. Целочисленное значение нижней границы вычисляется по следующей формуле

$$S^* = \left[\frac{V * T}{P} \right], \quad (1)$$

где $[]$ – целая часть числа, взятая с округлением вверх.

После нахождения нижней границы S^* необходимо выбрать такие A и L для формирования $S=A^L$, чтобы выполнялось неравенство (2).

$$S^* \leq S = A^L \quad (2)$$

При выборе S , удовлетворяющего неравенству (2), вероятность подбора пароля злоумышленником (при заданных V и T) будет меньше, чем заданная P .

Необходимо отметить, что при осуществлении вычислений по формулам (1) и (2), величины должны быть приведены к одним размерностям.

Пример

Исходные данные: $P=10^{-6}$, $T=7$ дней = 1 неделя, $V=10$ паролей / минуту = $10 \cdot 60 \cdot 24 \cdot 7 = 100800$ паролей в неделю.

$$\text{Тогда, } S^* = \left\lceil \frac{100800 \cdot 1}{10^{-6}} \right\rceil = 1008 \cdot 10^8.$$

Условию $S^* \leq A^L$ удовлетворяют, например, такие комбинации A и L , как $A=26$, $L=8$ (пароль состоит из 8 малых символов английского алфавита), $A=36$, $L=6$ (пароль состоит из 6 символов, среди которых могут быть малые латинские буквы и произвольные цифры).

ЗАДАНИЕ

1. В таблице 1 найти для вашего варианта значения характеристик P, V, T , а также группы символов, используемых при формировании пароля.
2. Вычислить мощность алфавита паролей A , соответствующую вашему варианту.
3. Вычислить по формуле (1) нижнюю границу S^* для заданных P, V, T .
4. Зная мощность алфавита паролей A , вычислить минимальную длину пароля L , при котором выполняется условие (2).
5. Используя программу Simple Passwords задать необходимые характеристики парольного генератора.
6. Сформировать в парольном генераторе Simple Passwords 10 паролей. Попытаться визуально выявить наиболее и наименее стойкие пароли.
7. Сформировать собственный (либо использовать реально существующий) пароль и произвести оценку его стойкости ко взлому, как среднее время, требуемое злоумышленнику для гарантированного взлома данного пароля. Оценка необходимо проводить по формуле $T=S/2V$. При расчете принять $V=10^6$ паролей в секунду. Рассчитанное время позволит обосновать выбор максимального срока действия данного пароля.

8. Написать программу «генератор пароля», с возможностью выбора набора символов (мощности).

Контрольные вопросы

1. Что понимается под идентификацией и аутентификацией пользователя?
2. Чем определяется стойкость ко взлому подсистемы идентификации и аутентификации пользователя?
3. Перечислите основные требования к выбору пароля.
4. Перечислите основные требования к подсистеме парольной аутентификации пользователя.
5. Для чего используются автоматические генераторы паролей?
6. Дает ли выполнение всех требований к паролям и к подсистеме парольной аутентификации полную гарантию от взлома данной подсистемы злоумышленником?
7. Как количественно оценить стойкость подсистемы парольной аутентификации ко взлому?
8. Как изменится стойкость ко взлому подсистемы парольной аутентификации при увеличении характеристик P, V, T ?
9. Как изменится стойкость к взлому подсистемы парольной аутентификации при уменьшении характеристик P, V, T ?
10. Какого среднего времени гарантированного взлома вашего пароля?

Таблица 1. Варианты заданий

Вариант	P	V	T	Используемые группы символов
1	10^{-4}	15 паролей/мин	2 недели	1. Цифры (0-9) 2. Латинские строчные буквы (a-z)
2	10^{-5}	3 паролей/мин	10 дней	1. Латинские прописные буквы (A-Z) 2. Русские строчные буквы (a-я)
3	10^{-6}	10 паролей/мин	5 дней	1. Русские прописные буквы (А-Я) 2. Специальные символы.
4	10^{-7}	11 паролей/мин	6 дней	1. Цифры (0-9) 2. Латинские прописные буквы (A-Z)
5	10^{-4}	100 паролей/день	12 дней	1. Русские прописные буквы (А-Я) 2. Латинские строчные буквы (a-z)
6	10^{-5}	10 паролей/день	1 месяц	1. Русские строчные буквы (a-я) 2. Специальные символы.
7	10^{-6}	20 паролей/мин	3 недели	1. Цифры (0-9) 2. Русские строчные буквы (a-я)
8	10^{-7}	15 паролей/мин	20 дней	1. Латинские строчные буквы (a-z) 2. Латинские прописные буквы (A-Z)
9	10^{-4}	3 паролей/мин	15 дней	1. Русские прописные буквы (А-Я) 2. Русские строчные буквы (a-я)
10	10^{-5}	10 паролей/мин	1 неделя	1. Цифры (0-9) 2. Специальные символы.
11	10^{-6}	11 паролей/мин	2 недели	1. Цифры (0-9) 2. Русские прописные буквы (А-Я)
12	10^{-7}	100 паролей/день	10 дней	1. Латинские строчные буквы (a-z) 2. Русские прописные буквы (А-Я)
13	10^{-4}	10 паролей/день	5 дней	1. Цифры (0-9) 2. Латинские строчные буквы (a-z)
14	10^{-5}	20 паролей/мин	6 дней	1. Латинские прописные буквы (A-Z) 2. Русские строчные буквы (a-я)
15	10^{-6}	15 паролей/мин	12 дней	1. Русские прописные буквы (А-Я) 2. Специальные символы.
16	10^{-7}	3 паролей/мин	1 месяц	1. Цифры (0-9) 2. Латинские прописные буквы (A-Z)
17	10^{-4}	10 паролей/мин	3 недели	1. Русские прописные буквы (А-Я) 2. Латинские строчные буквы (a-z)
18	10^{-5}	11 паролей/мин	20 дней	1. Русские строчные буквы (a-я) 2. Специальные символы.
19	10^{-6}	100 паролей/день	15 дней	1. Цифры (0-9) 2. Русские строчные буквы (a-я)
20	10^{-7}	10 паролей/день	1 неделя	1. Латинские строчные буквы (a-z) 2. Латинские прописные буквы (A-Z)